THE UNIVERSITY OF MELBOURNE

COMP90050 Advanced Database Systems

Semester 1, 2026

Lecturer: Farhana Choudhury (PhD)

Live lecture – Week 2

Logistics - Project

Step 1: Form a group of **4 students** by the end of Week 3

Step 2: Pick a topic of your interest from a list of candidate topics provided, by the end of Week 3

Canvas has details about the projects already: **Read** and **Start** with the steps above.

Logistics - Quiz

Quiz 1 (Week 3): Will be open on Tuesday 3pm, closes on Thursday 3pm (right before the live lecture)

– 20 minutes strict time to complete
– Open book
– You will need calculator (you can use on-screen calculator)
– Attempt all questions

Discussion on the topics of the pre-recorded lecture and additional contents

Core Concepts of Database management system

Database performance metrics

- Efficiency/speed
- Effectiveness
- Security & Reliability

Efficiency

- Hardware
  - Disks and I/O bandwidth
  - Main memory
  - Type of architecture
- Software/ DB tuning
  - Types of DB
  - Query optimisation

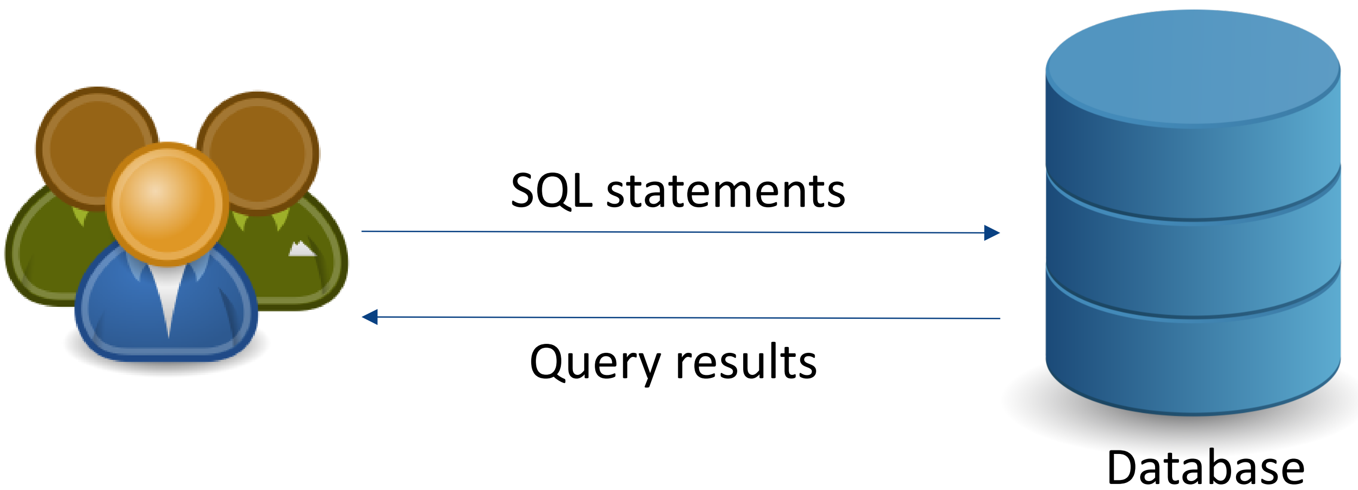
Effectiveness

- Concurrent users
- Transactions

Reliability

- Crash recovery
- Fault tolerance
- Data duplication

DB queries



Why very important for data science tasks too?

Efficiency is one of the most important requirements for client-facing databases

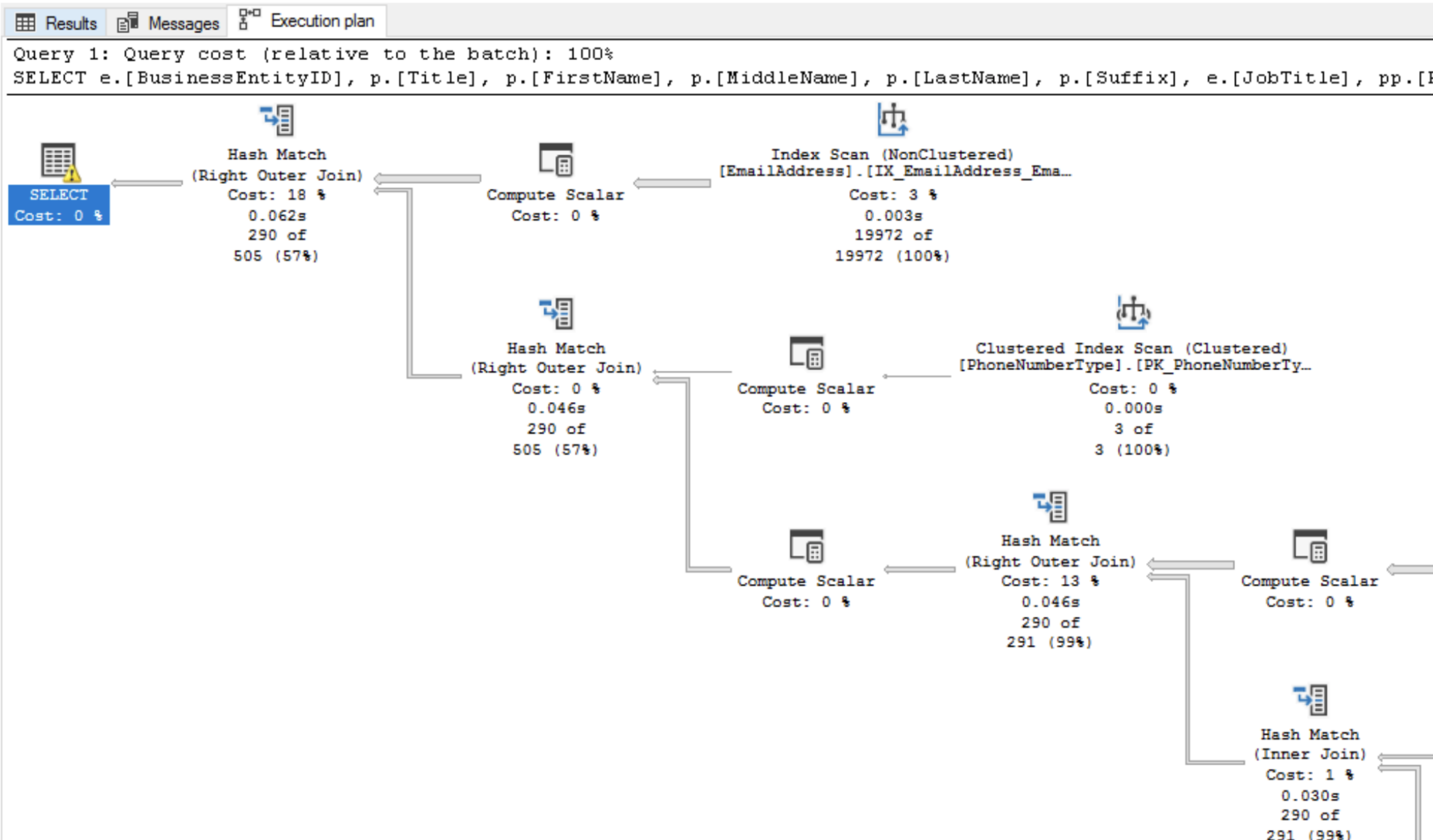
The best execution strategy to find the query results – an integral part of DBMS

How do query optimiser make the choices?

Steps in **<u>cost-based query optimisation</u>**

1. Generate logically equivalent expressions of the SQL statement
2. Annotate resultant expressions to get alternative query plans
3. Choose the cheapest plan based on the estimated cost

View an actual execution plan



https://docs.microsoft.com/en-us/sql/relational-databases/performance/display-an-actual-execution-plan?view=sql-server-ver16

How do query optimizer make the choices?

Steps in **<u>cost-based query optimisation</u>**

1. Generate logically equivalent expressions of the SQL statement

2. Annotate resultant expressions to get alternative query plans

3. Choose the cheapest plan based on the estimated cost

What is the cost of a query?

The number of pages/ disk blocks that are accessed from disk to answer the query

Most dominant cost
(Recall from memory hierarchy!

How do query optimiser make the choices?

Steps in **cost-based query optimisation**

1. Generate logically equivalent expressions of the SQL statement
2. Annotate resultant expressions to get alternative query plans
3. Choose the cheapest plan based on the estimated cost

Estimation of plan cost based on:

- Statistical information about tables. Example:

    number of distinct values for an attribute

- Statistics estimation for intermediate results to compute cost of complex expressions

- Cost formulae for algorithms, computed using statistics again

Query optimisation

For a cost-based query optimization, is the query optimiser optimistic or pessimistic about the query cost estimation?

A query cost is estimated as 3000 pages and it took 30ms to get the query results from the database. Another query cost is estimated as 1000 pages and it took 60ms to get the query results from the database. Can this be true?

Time for a poll - Pollev.com/farhanachoud585

Query optimisation

For a cost-based query optimization, is the query optimiser optimistic or pessimistic about the query cost estimation?

A query cost is estimated as 3000 pages and it took 30ms to get the query results from the database. Another query cost is estimated as 1000 pages and it took 60ms to get the query results from the database. Can this be true?

Estimations can be wrong – pre-recorded lecture

What if some pages are already in main memory? – Difference between logical reads and physical reads

Memory optimised table

Can you make a table stay in main memory?

```
CREATE TABLE dbo.Customer (
    CustomerID char (5) NOT NULL PRIMARY KEY,
    ContactName varchar (30) NOT NULL
) ENGINE=MEMORY;
```

Group project topics

- **Self-driving Databases** (In a nutshell: Databases that take over functions from the database administrators such as tuning, index selection, improve performance, etc.)
- **Graph databases** (Scalable graph storage, querying, etc.)

Performance tuning

When you identify a query with suboptimal performance, what can you do?

Time for another poll - Pollev.com/farhanachoud585

Performance tuning

When you identify a query with suboptimal performance, what can you do?

Time for another poll - Pollev.com/farhanachoud585

- Force a query plan instead of the plan chosen by the optimizer
- Do we need an index?
- Enforce statistic recompilation
- Rewrite query?
- Memory optimised table?

Source: https://docs.microsoft.com/en-us/sql/relational-databases/performance/best-practice-with-the-query-store?view=sql-server-ver16#Insight

Discussion topic – SQL injection

InfoQ Homepage > News > Security Experts Exploit Airport Security Loophole With SQL Injection

DEVELOPMENT

Security Experts Exploit Airport Security Loophole with SQL Injection

SEP 11, 2024 • 3 MIN READ LIKE

RELATED CONTENT

SQL injection vulnerability in MOVEit Transfer leads to data breaches worldwide

CYBERCRIME

Millions of User Records Stolen From 65 Websites via SQL Injection Attacks

The ResumeLooters hackers compromise recruitment and retail websites using SQL injection and XSS attacks.

By Ionut Arghire | February 6, 2024 (9:02 AM ET)

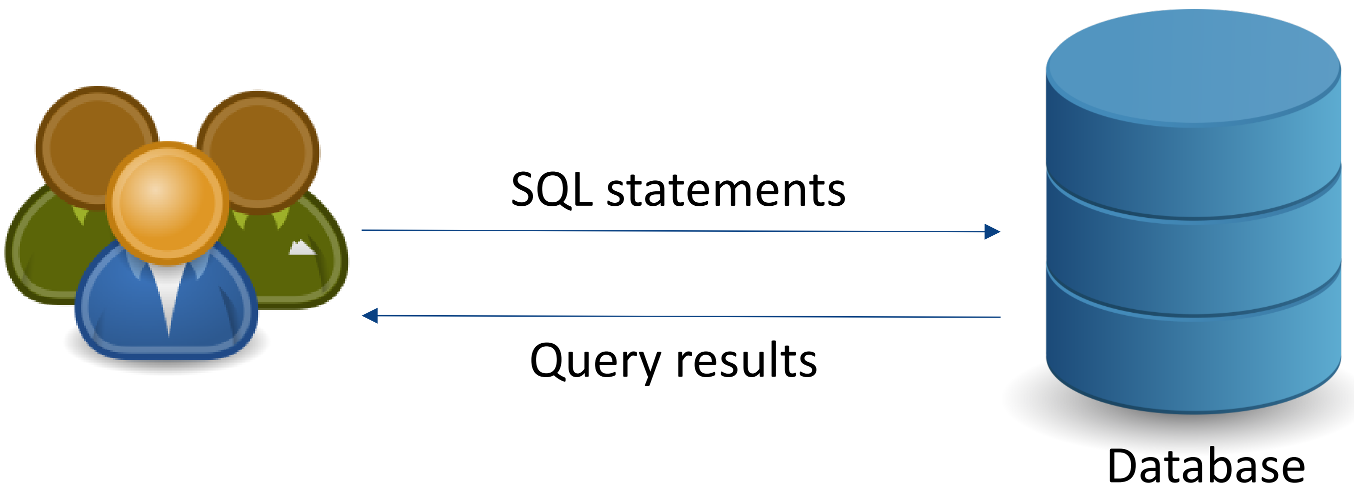
NBC NEWS 160 million credit cards later, 'cutting edge' hacking ring cracked SHARE & SAVE

TECH NEWS

160 million credit cards later, 'cutting edge' hacking ring cracked

For nearly a decade, a band of cybercriminals rampaged through the servers of a global business

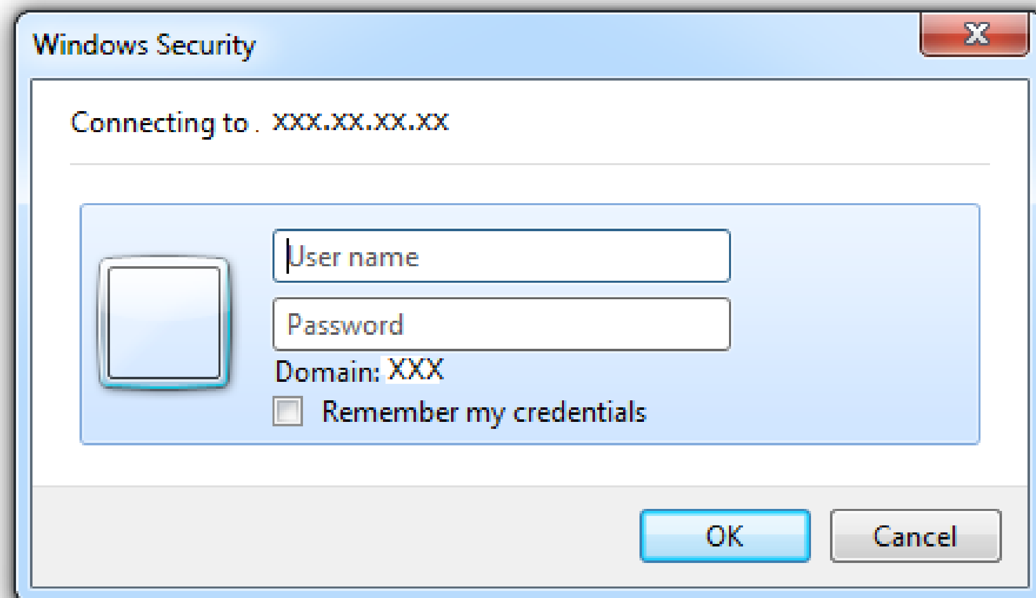
Discussion topic – SQL injection



Can happen when an application executes database query using user-input data, and the user input or part of the user input is treated as SQL statement

SQL syntax

SELECT * FROM `login` WHERE `user`=‘farhana’ AND `pass`=‘comp90050’



LOGIC: ‘a’=‘a’

Example: SELECT * FROM `table` WHERE ‘a’=‘a’

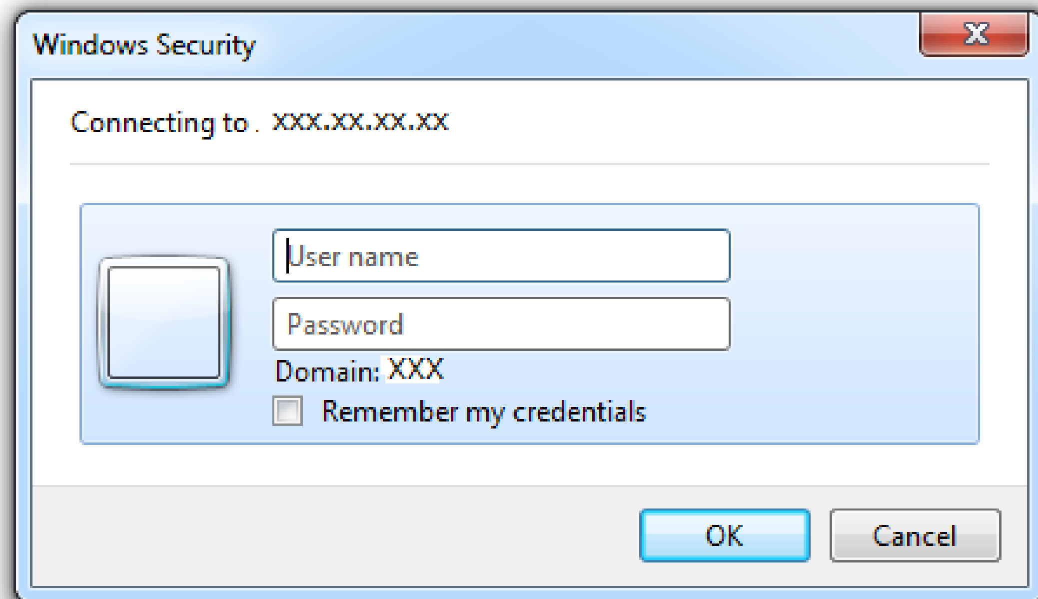
SELECT * FROM `login` WHERE `user`=‘’ OR ‘a’=‘a’ AND `pass`=‘’ OR ‘a’=‘a’

SQL syntax

MULTI STATEMENTS: S1; S2

Example: SELECT * FROM `table`; DROP TABLE `table`;

SELECT * FROM `login` WHERE `user`=‘<u>farhana</u>’ AND `pass`=‘<u>comp90050</u>’



Any statement(s) can go here

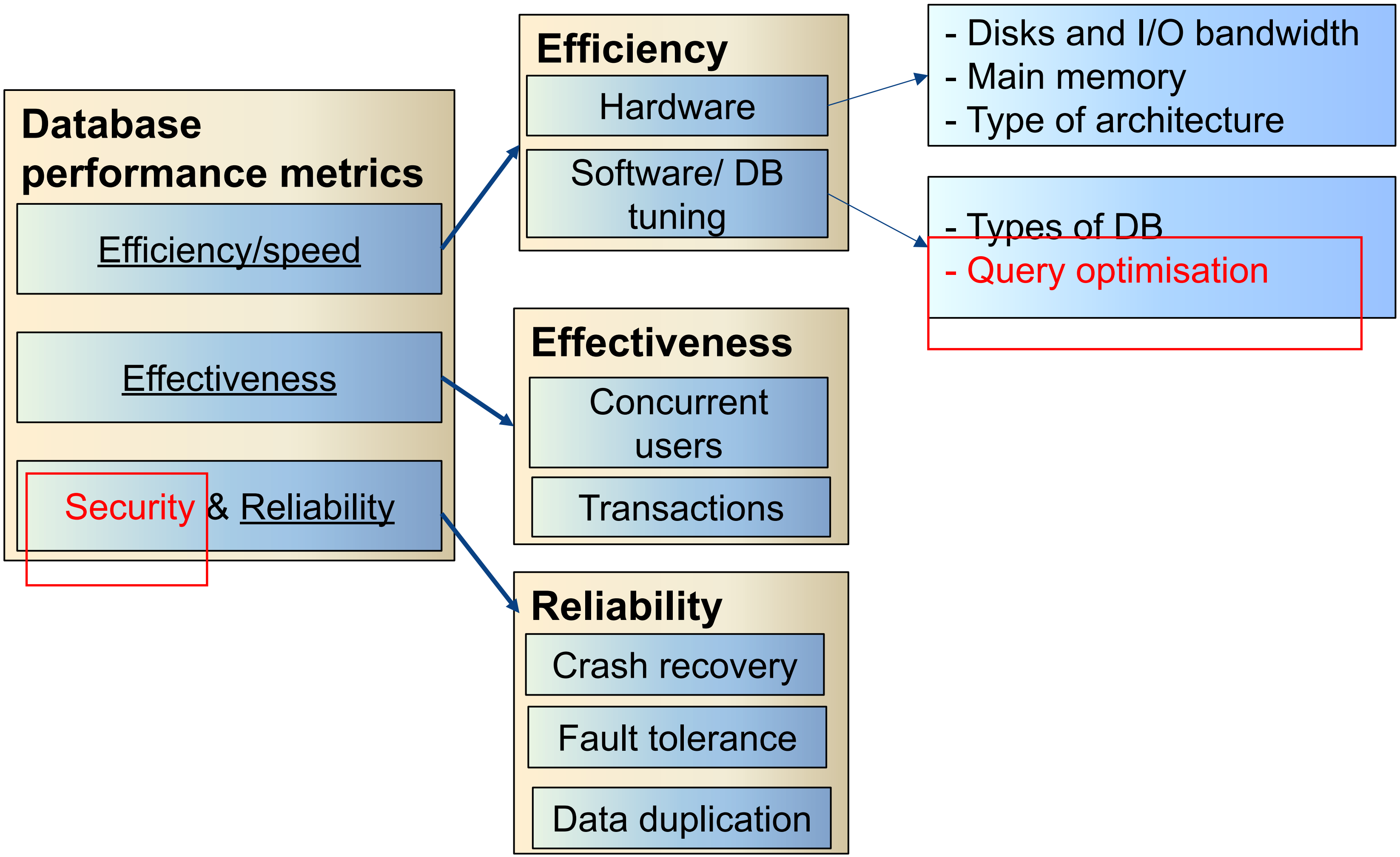
SELECT * FROM `login` WHERE `user`=‘<u>’; DROP TABLE `login`; --</u>’ AND `pass`=‘’

Prevention

User parameterized query/prepared statement - allows the database to distinguish between code and data

```
String query = "SELECT * from login where user = "
+ request.getParameter(”userName");
```

Summary


Database performance metrics
Efficiency/speed
Effectiveness
Security & Reliability
Efficiency
Hardware
Software/ DB tuning
- Disks and I/O bandwidth
- Main memory
- Type of architecture
- Types of DB
- Query optimisation
Effectiveness
Concurrent users
Transactions
Reliability
Crash recovery
Fault tolerance
Data duplication

Student representative

Are you interested in becoming a student representative?

if yes, send an email to:

farhana.choudhury@unimelb.edu.au

First come first priority